Vulnerability Assessment Report

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

This vulnerability assessment is focused exclusively on the **logical and network-level security** of the **remote database server**, specifically addressing its current public-facing accessibility. The assessment utilizes the **NIST SP 800-30 Rev. 1** framework to evaluate the risk to customer data confidentiality and integrity. The boundaries of this report are limited to **digital access controls** and the network configuration of the database; all other IT systems and physical security measures fall outside the current evaluation parameters.

Purpose

The remote database server is a vital business asset that enables our global workforce to query the customer data necessary for driving sales and daily operations. It is critical to secure this information to maintain customer trust and protect the company from the severe legal and financial consequences of a data breach. If this server were disabled or compromised, the company's ability to identify potential customers would cease, leading to a total disruption of business activities. Therefore, this assessment aims to identify a path toward securing this data while ensuring the system remains accessible and functional for authorized employees.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Employee	*Alter/Delete critical information*	*2*	*3*	*6*
Hacker	*Conduct Denial of Service (DoS) attacks.*	*3*	*3*	*9*
Supplier	*Obtain sensitive information via exfiltration*	*2*	*3*	*6*

Approach

The rationale for selecting these specific risks such as **Hackers (DoS)**, **Suppliers (Exfiltration)**, and **Employees (Data Alteration)** stems from the direct threat they pose to the availability and confidentiality of our core business asset. Likelihood and severity scores were derived by analyzing the database's three-year public exposure against the operational needs of our global remote workforce. These risks are significant as they could lead to total revenue loss or irreversible reputational damage.

Remediation Strategy

To address the risks, I recommend implementing:

- **Firewalls**
- **VPNs**
- **Multi-Factor Authentication (MFA)**
- **Role-Based Access Control (RBAC)**

A firewall will immediately close the database to the public and block Denial of Service (DoS) attacks, while a VPN ensures remote employees have a private, encrypted tunnel to connect safely. Adding MFA prevents hackers or suppliers from using stolen passwords to exfiltrate data, as it requires two or more ways for verification. Finally, RBAC limits employees to "read-only" permissions, ensuring they can query customer data without having the power to accidentally alter or delete critical records. This multi-layered approach secures the "front door" of the server while strictly controlling what users can do once they are inside.